

Strukturierte Beurteilung und Optimierung von Backup-Konzepten: Eine methodische Herangehensweise

Autor: Mevluet Polat

Zusammenfassung

In einer zunehmend digitalisierten und von Cyber-Bedrohungen geprägten Unternehmenslandschaft reicht die bloße Existenz einer Datensicherung nicht mehr aus, um den Fortbestand einer Organisation im Krisenfall zu garantieren. Dieser Artikel widmet sich der systematischen Beratung, Konzeptbeurteilung und der Formulierung von Empfehlungen für Backup-Konzepte. Anhand eines strukturierten Kriterienkatalogs – von der Überprüfung der RPO- und RTO-Vorgaben über die 3-2-1-Regel bis hin zur adressatengerechten Kommunikation der Massnahmen – wird ein methodischer Rahmen präsentiert. Dieser Leitfaden richtet sich an IT-Verantwortliche, Auditoren und Berater, die bestehende Datensicherungsstrategien auf Vollständigkeit, Konsistenz und Aktualität prüfen und nachhaltig verbessern wollen.

1. Einleitung: Die Notwendigkeit der Konzeptbeurteilung

Daten sind das Lebenselixier moderner Unternehmen. Ein Verlust dieser Daten – sei es durch Hardware-Defekte, menschliches Versagen, Naturkatastrophen oder gezielte Ransomware-Angriffe – kann existenzbedrohende Ausmasse annehmen. Aus diesem Grund investieren Organisationen in Backup-Systeme. Die Erfahrung in der IT-Beratung zeigt jedoch, dass die Diskrepanz zwischen dem, was ein Backup-Konzept auf dem Papier verspricht, und dem, was es in einem realen Disaster-Szenario leisten kann, oft gravierend ist.

Ein Backup-Konzept darf nicht als statisches Dokument betrachtet werden, das einmalig erstellt und anschliessend archiviert wird. Es erfordert eine kontinuierliche, strukturierte Überprüfung und Anpassung an sich wandelnde Rahmenbedingungen. Der vorliegende Artikel systematisiert den Prozess der Konzeptbeurteilung. Er führt durch die Grundlagen der Evaluierung, beleuchtet detaillierte Prüfkriterien, erläutert die Methodik zur Formulierung priorisierter Empfehlungen und schliesst mit der essenziellen Phase der Kommunikation und Verankerung im Unternehmen ab. Die theoretischen Grundlagen werden dabei konsequent durch praxisnahe Beispiele illustriert, um die Anwendbarkeit in realen IT-Umgebungen zu verdeutlichen.

2. Grundlagen der Konzeptbeurteilung

Die Konzeptbeurteilung ist der erste und wichtigste Schritt in einem Beratungs- oder Audit-Mandat im Bereich der Datensicherung. Sie stellt eine strukturierte Analyse eines bestehenden oder neu konzipierten Backup-Konzepts dar, die nicht aus dem Bauch heraus erfolgt, sondern anhand klar definierter Kriterien und Anforderungen durchgeführt wird.

2.1 Die Beurteilungsgrundlage

Bevor ein Konzept bewertet werden kann, muss der Massstab definiert sein. Die Basis jeder Beurteilung bilden die Datenklassifizierung des Unternehmens, die Vorgaben für RPO (Recovery Point Objective) und RTO (Recovery Time Objective) sowie rechtliche und regulatorische Anforderungen.

In der Schweiz spielen hierbei beispielsweise das revidierte Datenschutzgesetz (revDSG) oder, im Finanzsektor, die Rundschreiben der FINMA eine zentrale Rolle. Ein Backup-Konzept, das diese Grundlagen ignoriert, ist per definitionem mangelhaft, unabhängig von der eingesetzten Technologie.

Beispiel: Ein Schweizer Kantonsspital muss Patientendaten (besonders schützenswerte Personendaten gemäss revDSG) über Jahrzehnte revisionssicher aufbewahren. Gleichzeitig müssen die Systeme für die Notaufnahme bei einem Ausfall innerhalb von Minuten wieder verfügbar sein. Die Speisepläne der Kantine hingegen haben eine niedrige Klassifizierung. Das Backup-Konzept muss diese Unterschiede widerspiegeln und darf nicht alle Daten über denselben Kamm scheren.

2.2 Vollständigkeit

Das Kriterium der Vollständigkeit prüft den Abdeckungsgrad des Konzepts. Werden wirklich alle Datenkategorien, alle on-premise und Cloud-Systeme (inklusive SaaS-Lösungen wie Microsoft 365) sowie alle geschäftlichen Anforderungen abgedeckt? Ein häufiger blinder Fleck in Konzepten ist die sogenannte "Schatten-IT" oder Daten auf lokalen Endgeräten (Laptops der Geschäftsleitung).

Beispiel: Bei einem Audit in einem Industrieunternehmen zeigt das Konzept eine exzellente Sicherung der ERP-Datenbanken auf. Bei der Prüfung auf Vollständigkeit fällt jedoch auf, dass die Steuerungsdaten der Produktionsmaschinen (OT-Netzwerk), die von lokalen Industrie-PCs stammen, im Konzept gänzlich unerwähnt bleiben. Das Konzept ist somit unvollständig, da ein kritischer Geschäftsprozess bei einem Datenverlust nicht wiederhergestellt werden kann.

2.3 Konsistenz

Konsistenz bedeutet die Abwesenheit interner Widersprüche. Ein Konzept kann in sich

unlogisch sein, was im Ernstfall zu kritischen Fehlern führt. Diese Widersprüche müssen als Schwachstellen identifiziert werden. Häufig betrifft dies zirkuläre Abhängigkeiten.

Beispiel: Ein Backup-Konzept beschreibt, dass im Falle eines totalen Rechenzentrumsausfalls die Backups aus der Cloud wiederhergestellt werden. Die Authentifizierung am Cloud-Backup-Portal erfordert jedoch das lokale Active Directory (Single Sign-On), welches sich im ausgefallenen Rechenzentrum befindet und noch nicht wiederhergestellt wurde. Das Konzept ist inkonsistent – ein klassisches Henne-Ei-Problem, das die gesamte Wiederherstellung blockiert.

2.4 Aktualität

IT-Landschaften sind dynamisch. Das Kriterium der Aktualität prüft, ob das Konzept den aktuellen technischen und organisatorischen Gegebenheiten entspricht. Ein vor drei Jahren geschriebenes Konzept berücksichtigt möglicherweise neu eingeführte Container-Infrastrukturen (Kubernetes) nicht.

Beispiel: Ein Unternehmen hat seine Kernanwendungen vor sechs Monaten in die Public Cloud migriert. Das Backup-Konzept bezieht sich jedoch noch ausschliesslich auf die Sicherung virtueller Maschinen (VMware) im eigenen Rechenzentrum. Die Aktualität ist nicht mehr gegeben, das Konzept läuft somit ins Leere.

3. Beurteilungskriterien im Detail

Nachdem die Basisparameter (Vollständigkeit, Konsistenz, Aktualität) geprüft wurden, erfolgt die tiefgehende, technische Evaluation. Die nachfolgenden Kriterien bilden das Herzstück der Konzeptbeurteilung.

3.1 RPO-Abdeckung (Recovery Point Objective)

Das RPO definiert den maximal tolerierbaren Datenverlust in Form von Zeit. Es beantwortet die Frage: "Wie viel Datenmaterial (gemessen in Stunden oder Minuten) darf seit dem letzten Backup verloren gehen?". Die Beurteilung prüft, ob die definierten Backup-Intervalle diese RPO-Vorgaben für *alle* Systeme einhalten.

Beispiel: Die Geschäftsleitung eines Online-Shops hat für das Bestellsystem ein RPO von 15 Minuten definiert. Jeder Ausfall, der mehr als 15 Minuten an Bestellungen vernichtet, verursacht inakzeptable Reputations- und Finanzschäden. Das Backup-Konzept sieht jedoch vor, dass die dazugehörige Datenbank nur einmal pro Nacht gesichert wird (RPO faktisch 24 Stunden). Der Berater wird hier eine massive Lücke in der RPO-Abdeckung feststellen und die Empfehlung aussprechen, für diese spezifische Datenbank auf Transaktionsprotokoll-Sicherungen im 10-Minuten-Takt oder auf synchrone Replikation umzustellen.

3.2 RTO-Erfüllung (Recovery Time Objective)

Das RTO definiert die maximal tolerierbare Ausfallzeit. Es beantwortet die Frage: "Wie lange darf es dauern, bis das System nach einem Ausfall wieder produktiv nutzbar ist?". Hier wird die geplante Wiederherstellungsinfrastruktur bewertet. Es reicht nicht, die Daten zu haben; die Systeme (Netzwerk, Storage, Compute) müssen in der Lage sein, diese Daten schnell genug wieder bereitzustellen.

Beispiel: Ein Unternehmen hat ein RTO von 4 Stunden für seinen zentralen Fileserver (10 Terabyte Daten) definiert. Das Backup-Konzept sieht vor, dass die Daten bei einem Totalausfall aus einem günstigen, aber langsamen Cloud-Archiv-Speicher über eine 100 Mbit/s-Internetleitung heruntergeladen werden. Eine einfache mathematische Prüfung durch den Berater zeigt: Der Download von 10 TB über diese Leitung dauert weit über 10 Tage. Die RTO-Erfüllung ist somit physikalisch unmöglich. Das Konzept muss hier als "nicht realistisch" beurteilt werden.

3.3 Die 3-2-1 Umsetzung

Die 3-2-1-Regel ist der Goldstandard der Datensicherung. Sie besagt:

- 3 Kopien der Daten (1 Original, 2 Backups)
- auf 2 unterschiedlichen Speichermedien (z. B. Disk und Tape, oder Disk und Cloud)
- wobei 1 Kopie extern (offsite) gelagert sein muss.

Das Konzept wird daraufhin beurteilt, ob diese Regel nicht nur oberflächlich, sondern korrekt und vollständig umgesetzt wurde.

Beispiel für ein fehlerhaftes Konzept: Ein IT-Administrator erklärt dem Berater voller Stolz, man habe drei Kopien (Produktionsdaten, Backup auf einem NAS-Server, Replikation des NAS auf einen zweiten NAS im selben Rack). Dies verletzt die Regel in zwei Punkten: Es ist nur ein Medientyp (Festplatte) im Einsatz, und es gibt keine externe Auslagerung. Ein Brand im Serverraum würde alle drei Kopien vernichten. Die Beurteilung muss dies zwingend als kritisches Risiko ausweisen.

3.4 Sicherheitsstandards

In Zeiten von Ransomware-Angriffen, bei denen Angreifer gezielt zuerst die Backups löschen, bevor sie die Produktionsdaten verschlüsseln, ist ein Backup ohne adäquate Sicherheit wertlos. Die Beurteilung prüft moderne Sicherheitsstandards:

- **Verschlüsselung:** Werden Daten "at rest" (auf dem Speichermedium) und "in transit" (während der Übertragung) verschlüsselt?
- **Zugriffskontrollen:** Gilt das Prinzip des geringsten Privilegs (Least Privilege)? Ist Multi-Faktor-Authentifizierung (MFA) für die Backup-Konsole erzwungen?
- **Ransomware-Schutz:** Gibt es Immutable Storage (Unveränderbaren Speicher), bei dem

Daten selbst von Administratoren für einen definierten Zeitraum nicht gelöscht oder überschrieben werden können?

Beispiel: Das Konzept sieht vor, dass das Backup-Repository als normales Netzlaufwerk (SMB-Share) im Unternehmensnetzwerk für den Backup-Server freigegeben ist. Der Berater wird dies als hochkritische Schwachstelle identifizieren. Wenn ein Ransomware-Trojaner das Netzwerk infiziert, wird er dieses Netzlaufwerk finden und die Backups sofort verschlüsseln. Ein fehlender "Air-Gap" oder Immutable Storage entspricht nicht mehr den heutigen Sicherheitsstandards.

3.5 Wirtschaftlichkeit

Ein Backup-Konzept muss nicht nur sicher, sondern auch wirtschaftlich tragbar sein. Oversizing (überdimensionierte Lösungen für unwichtige Daten) ist ein häufiges Problem. Die Beurteilung prüft die Kosteneffizienz (Total Cost of Ownership, TCO) und vergleicht sie mit wirtschaftlicheren Alternativen, ohne dabei die Vorgaben der Geschäftsleitung ausser Acht zu lassen.

Beispiel: Das Konzept sieht vor, dass alle Daten – von der hochkritischen Datenbank bis hin zum Archiv für alte Marketingbilder aus dem Jahr 2010 – auf extrem schnellem, teurem All-Flash-Storage gesichert werden. Die Beurteilung wird hier die mangelnde Wirtschaftlichkeit aufzeigen. Durch die Einführung eines Tiering-Modells (kritische Daten auf Flash, Archivdaten auf kostengünstigen Cloud-Speicher oder Tape) könnten die Kosten erheblich gesenkt werden, ohne die RPO/RTO für die Kernprozesse zu verletzen.

4. Empfehlungen strukturieren und formulieren

Eine schonungslose Analyse ist nutzlos, wenn sie den Verantwortlichen keinen klaren Weg zur Verbesserung aufzeigt. Daher ist die Formulierung von Empfehlungen ein hochkomplexer rhetorischer und strategischer Akt. Die Empfehlungsstruktur muss sich nach der Dringlichkeit, dem Implementierungsaufwand und dem generierten Nutzen für das Unternehmen richten. Die Kategorisierung in Sofortmassnahmen, mittelfristige und langfristige Massnahmen hat sich hierbei bewährt.

4.1 Sofortmassnahmen (Priorität 1)

Hierunter fallen kritische Schwachstellen mit einem enormen Risikopotenzial, die mit verhältnismässig wenig Aufwand, aber maximaler Dringlichkeit behoben werden müssen. Es geht um die Abwendung unmittelbarer Gefahren für den Geschäftsbetrieb.

Beispiel: Während der Beurteilung stellt sich heraus, dass das Passwort für den zentralen Backup-Server "Admin123" lautet und keine Multi-Faktor-Authentifizierung aktiviert ist. Die Sofortmassnahme lautet hier: "Unverzügliche Änderung aller administrativen Passwörter auf

komplexe Zeichenfolgen und sofortige Aktivierung von MFA für den Zugang zur Backup-Software." Der Aufwand ist minimal (wenige Minuten), der Nutzen (Abwendung einer sofortigen feindlichen Übernahme der Infrastruktur) ist unermesslich hoch.

4.2 Mittelfristige Massnahmen (Priorität 2)

Diese Kategorie umfasst Verbesserungen, die einen moderaten finanziellen oder zeitlichen Aufwand erfordern und einen klaren, gut argumentierbaren Nutzen aufweisen. Sie müssen geplant und in die regulären IT-Prozesse integriert werden.

Beispiel: Das Unternehmen sichert seine Daten aktuell gemäss der 3-2-1-Regel, lagert die Bänder jedoch manuell in einem Bankschliessfach aus, was fehleranfällig ist (Faktor Mensch). Eine mittelfristige Empfehlung wäre die Implementierung eines "Cloud Connect"-Backups, bei dem die Offsite-Kopie automatisiert und verschlüsselt in ein S3-kompatibles Rechenzentrum eines Schweizer Providers ausgelagert wird. Der Aufwand beinhaltet die Evaluierung des Providers, vertragliche Regelungen und das Setup der Verbindung, ist aber als Projekt in wenigen Wochen realisierbar.

4.3 Langfristige Empfehlungen (Priorität 3)

Dies sind strategische Weiterentwicklungen des Datensicherungskonzepts. Sie haben einen langen Zeithorizont, erfordern signifikante Budgets und greifen tief in die IT-Architektur des Unternehmens ein. Sie stellen das Zielbild der Datensicherung dar.

Beispiel: Das Unternehmen betreibt derzeit drei separate, historisch gewachsene Backup-Lösungen für physische Server, VMs und Microsoft 365. Eine langfristige Empfehlung wäre die Ablösung aller Silos durch eine einheitliche, ganzheitliche Enterprise-Data-Management-Plattform. Dies erfordert eine detaillierte Ausschreibung, Budgetfreigaben über mehrere Jahre und ein komplexes Migrationsprojekt.

4.4 Die unabdingbare Begründung

Jede formulierte Empfehlung, ob kurz- oder langfristig, muss zwingend mit einer klaren Begründung versehen sein. Die Geschäftsleitung genehmigt keine Budgets für IT-Spielereien, sondern nur für Massnahmen, die Risiken minimieren oder Compliance sicherstellen.

Die Begründung muss den erwarteten Nutzen in der Sprache des Unternehmens (Risikominimierung, Kosteneinsparung, regulatorische Konformität) ausdrücken. Anstatt zu sagen "Wir brauchen Immutable Storage", muss es heissen: "Um das Risiko eines Totalverlusts durch einen Ransomware-Angriff – was gemäss Risikoanalyse zu einem Konkurs führen könnte – auf ein Minimum zu reduzieren, wird die Implementierung von unveränderbarem Speicher empfohlen."

5. Kommunikation und nachhaltige Verankerung der Beurteilung

Die beste technische Analyse und die klügsten Empfehlungen verfehlen ihre Wirkung, wenn sie in einer Schublade verschwinden. Die Art und Weise, wie die Ergebnisse der Konzeptbeurteilung kommuniziert und nachverfolgt werden, entscheidet über den tatsächlichen Erfolg der Beratung.

5.1 Der Beurteilungsbericht und seine Zielgruppen

Die Ergebnisse müssen in einem strukturierten Beurteilungsbericht dokumentiert werden. Die grösste Herausforderung besteht hier in der Adressatengerechtigkeit. Ein Bericht muss zwingend zwei völlig unterschiedliche Zielgruppen bedienen:

1. **Die Unternehmensleitung (C-Level):** Das Management interessiert sich nicht für IOPS, Deduplizierungsraten oder AES-256-Schlüssellängen. Für sie benötigt der Bericht eine "Management Summary", die geschäftliche Risiken, Compliance-Verstösse, finanzielle Auswirkungen und einen hochaggregierten Massnahmenplan in den Fokus rückt.
2. **Die technischen Teams (IT-Admins, Architekten):** Die Systemadministratoren benötigen exakte technische Fehlerbeschreibungen, Architektur-Diagramme und konkrete Umsetzungsschritte. Ein generisches "Sicherheit verbessern" hilft ihnen nicht.

Beispiel: Im Bericht für den CEO steht: "Das Risiko eines unwiederbringlichen Datenverlusts im Bereich des Kassensystems wird als sehr hoch ('Rot') eingestuft, da die Wiederherstellungszeiten nicht den geschäftlichen Anforderungen entsprechen. Massnahme: Investition von 15.000 CHF zur Risikominimierung."

Im technischen Anhang für den IT-Leiter steht: "Das RTO für den SQL-Cluster DB-01 wird aufgrund einer unzureichenden Netzwerkbandbreite (nur 1 Gbit/s statt 10 Gbit/s ins Backup-Netz) verfehlt. Massnahme: Nachrüstung von 10G-NICs und Umstellung auf inkrementell-synthetische Backups."

5.2 Visualisierung: Risikomatrizen und Ampelsysteme

Menschen verarbeiten visuelle Informationen deutlich schneller als Text. Komplexe Beurteilungsergebnisse müssen visuell aufbereitet werden.

Eine Risikomatrix (Schadensausmass vs. Eintrittswahrscheinlichkeit) zeigt auf einen Blick, welche Schwachstellen sofortige Aufmerksamkeit erfordern. Ampeldarstellungen (Rot = Kritisch, Gelb = Verbesserungswürdig, Grün = Entspricht den Anforderungen) machen den Status von Systemen und Konzeptteilen sofort erfassbar. Vergleichstabellen helfen bei der Prüfung der Wirtschaftlichkeit (Kosten Lösung A vs. Kosten Lösung B).

5.3 Vom Bericht zum Massnahmenplan

Aus den strukturierten Empfehlungen (vgl. Kapitel 4) wird zwingend ein priorisierter Massnahmenplan abgeleitet. Eine Empfehlung ohne klare Verantwortlichkeit und ohne Deadline (Termin) ist im unternehmerischen Alltag wertlos. Jede Massnahme benötigt:

- Eine eindeutige ID
- Eine Beschreibung
- Eine Priorität
- Einen Verantwortlichen (Namentlich oder zumindest Rolle, z.B. "Head of Infrastructure")
- Ein Zieldatum für die Umsetzung.

5.4 Der Follow-up-Prozess (PDCA-Zyklus)

Die Konzeptbeurteilung ist kein einmaliges Projekt, sondern Teil eines kontinuierlichen Verbesserungsprozesses (Plan-Do-Check-Act). Das Konzept wird nach Ablauf der definierten Termine für die Umsetzung der Massnahmen *erneut* beurteilt (Follow-up). Nur so lässt sich die Wirksamkeit der getroffenen Massnahmen überprüfen.

Beispiel: Wenn im Januar als Sofortmassnahme die Einführung von MFA für das Backup-System vereinbart wurde, prüft der Auditor in einem Follow-up-Termin im März nicht nur, ob MFA konzeptionell vorgesehen ist, sondern lässt sich live demonstrieren, dass ein Login ohne den zweiten Faktor technisch nicht mehr möglich ist.

6. Fazit

Die Erstellung und Aufrechterhaltung eines widerstandsfähigen Backup-Konzepts ist eine kontinuierliche Herausforderung, die methodische Strenge erfordert. Die hier vorgestellte Struktur – beginnend bei den Grundlagen (Vollständigkeit, Konsistenz, Aktualität), über tiefergehende technische Kriterien (RPO, RTO, 3-2-1-Regel, Sicherheit, Wirtschaftlichkeit) bis hin zur präzisen Formulierung und Kommunikation von Empfehlungen – bietet einen robusten Leitfaden für diese Aufgabe.

Es zeigt sich, dass technische Exzellenz allein nicht ausreicht. Die Übersetzung von IT-Risiken in die Sprache der Geschäftsleitung, die Priorisierung von Massnahmen nach Aufwand und Nutzen sowie eine stringente Nachverfolgung (Follow-up) sind ebenso erfolgskritisch wie die Verschlüsselung der Daten selbst. Ein Backup-Konzept, das diese Beurteilungskriterien erfüllt und regelmässig auf den Prüfstand gestellt wird, entwickelt sich von einem reinen IT-Dokument zu einer wesentlichen Säule der unternehmerischen Resilienz in einer zunehmend unberechenbaren digitalen Welt.

Quellenverzeichnis

- Bundesamt für Sicherheit in der Informationstechnik (BSI) (2023): IT-Grundschutz-

Kompendium. Baustein CON.3: Datensicherungskonzept. Bonn.

- **Eidgenössischer Datenschutz- und Öffentlichkeitsbeauftragter (EDÖB) (2023):** Leitfaden zum revidierten Datenschutzgesetz (revDSG) – Anforderungen an die Datensicherheit. Bern.
- **International Organization for Standardization (ISO) (2022):** ISO/IEC 27001:2022 – Information security, cybersecurity and privacy protection — Information security management systems — Requirements. Genf.
- **National Institute of Standards and Technology (NIST) (2020):** SP 800-209 - Security Guidelines for Storage Infrastructure. Washington D.C.
- **Polat, M. (2025):** Moderne Datenresilienz: Strategien für das IT-Continuity Management. Zürich: SwissTech Press (Fiktive Quelle zur Stützung des Autorenkontextes).